Project C - Authentication Guide

1. Summary

Project C also uses JWT, but tokens are signed with RS256 using a rotating key pair, and access tokens expire after 5 minutes. Every token carries a tenant_id claim that identifies the merchant.

2. Why RS256

Asymmetric signing means the Auth Service holds the private key and every other service verifies tokens with the public key only. A compromised downstream service therefore cannot forge tokens. This was a deliberate difference from earlier internal projects that used a shared secret.

3. Key rotation

The key pair is rotated every 24 hours. Public keys are published at a JWKS endpoint and each token header carries a kid value so verifiers can choose the right key. Old public keys remain published for 10 minutes after rotation so in-flight tokens still validate.

4. Claims

Required claims: sub, iss, aud, iat, exp, jti and tenant_id. Services must reject any token whose tenant_id does not match the tenant of the resource being accessed. This check is the main defence against cross-tenant data leaks.

5. Token issuance

Merchants obtain tokens by calling /oauth/token with a client identifier and a client secret over mutual TLS. The Auth Service verifies the credentials, creates the token and records its jti in the token store so that it can be revoked before expiry.

6. Revocation

Because tokens live only five minutes, revocation is handled by a deny-list of jti values held in the token store. The API gateway checks the deny-list on each request; entries are removed automatically once the token would have expired.